1. Overview

This document describes the session authentication for the practice notes web app. A user signs in with an email and password, and the server then identifies the browser on later requests with two tokens: a short-lived access token and a longer-lived refresh token.

2. Token storage

Both tokens are stored in cookies marked HttpOnly, Secure and SameSite=Strict. I chose cookies over local storage because JavaScript on the page cannot read an HttpOnly cookie, so a cross-site scripting bug cannot steal the tokens. Local storage is readable by any script on the page, which makes one such bug enough to take over an account. The SameSite setting stops the browser from sending the cookies on requests started by other sites.

The access token lives for 15 minutes. The refresh token lives for 14 days and is sent only to the refresh endpoint, through a cookie whose path is limited to that endpoint.

3. Refreshing a session

When the access token expires, the browser calls the refresh endpoint. The server checks the refresh token and, if it is valid, issues a new access token. The user stays signed in without typing the password again for as long as the refresh token is valid.

4. Threat model

Cross-site scripting: the main protection is the HttpOnly cookie, backed by a content security policy that blocks inline scripts. An attacker who runs a script can still make requests as the user while the page is open, but cannot copy the tokens to use elsewhere.

Cross-site request forgery: SameSite=Strict cookies, plus a check that the Origin header of every state-changing request matches our own site.

Token theft from the network: all traffic uses HTTPS, and the Secure flag keeps the cookies off plain HTTP.

Password guessing: sign-in attempts are rate limited per account and per address, and passwords are stored only as salted hashes.

5. Tests

All the auth tests pass.